

## **Lab Session 3B: Password Auditing & Hash Cracking — Part B: Online Brute Forcing with Hydra**

**Date:** 6 July 2026

**Duration:** 2 hours (including troubleshooting)

### **Scenario:**

*Continuing from the forensic scenario in Part A, the compromised server had a locked SSH service that needed to be tested for weak credentials. FTP was also running on the server. Hydra was used to perform a dictionary attack against both services to identify weak login credentials that could allow an attacker persistent access.*

### **Objective:**

*Perform online brute force attacks against a live target service using Hydra. Unlike John the Ripper, which works offline against hash files, Hydra attacks live running services in real time testing each username and password combination against the actual authentication system.*

### **Environment:**

**Virtual Machines:** Kali Linux (Live USB) +( Metasploitable 2 (VB)

**Service:** FTP (port 21) switched from SSH (port22) due to incompatibility

**Tools Used:** Hydra v9.6

**Target:** 192.168.56.105 (Metasploitable 2)

**Wordlists:** rockyou.txt + custom wordlist (custom.txt)

## **Pre LAB issues**

Before the lab could begin, Metasploitable 2 refused to start, throwing the error: 'Nonexistent host networking interface, name vboxnet0'. The host-only network adapter had dropped between sessions. To fix this I ran:

```
sudo modprobe vboxnetadp
```

```
sudo modprobe vboxnetflt
```

That was successful and vboxnet0 was recreated, after that Metasploitable started without any other problem and I was ready to begin.

## **First Attempt:**

My first attempt was to bruteforce SSH on port 22, I ran the following commands:

```
hydra -l msfadmin -P /usr/share/wordlists/rockyou.txt
```

```
ssh://192.168.105 -t 4 -v -o hydra_results.txt
```

That threw a kex error. Research into the issue suggested that Hydra could not establish the SSH connection because Metasploitable's old SSH server only supports legacy MAC algorithms (hmac-md5, hmac-sha1), while modern Kali SSH client defaults to current standards (hmac-sha2, hmac-sha2-512)

## **Fix**

To fix the error, I attempted to add legacy algorithm support to the SSH config file. After a few attempts and a few errors where I kept duplicating entries and having a few typos (I kept writing 'diffie helman' instead of 'diffie hellman'), the config file was rebuilt cleanly using a heredoc from there using:

```
Cat > ~/.ssh/config << 'EOF'
```

***Host \****

***KexAlgorithms +diffie-hellman-group1-sha1***

***HostKeyAlgorithms +ssh-rsa***

***MACs +hmac-md5***

***EOF***

This fixed SSH itself and login to Metasploitable succeeded:

***ssh -o KexAlgorithms=+diffie-hellman-group1-sha1 -o***

***HostKeyAlgorithms=+ssh-rsa -o MACs=+hmac-md5***

***msfadmin@192.168.56.105***

Although logging into Metasploitable was successful, Hydra still threw the kex error and that called for attempt 2:

### **Attempt 2 –Ftp Brute Forcing**

I decided to switch to FTP instead of SSH to see if the kex error would persist, first I verified FTP access:

***ftp 192.168.56.105***

***# Username: msfadmin***

***# Password: msfadmin***

Which was a success and login was successful. From there , I ran Hydra against it using rocky.txt:

***hydra -l msfadmin -P /usr/share/wordlists/rockyou.txt***

*ftp://192.168.56.105 -t 1 -V -o hydra\_results.txt*

-t was reduced to 1 after Metasploitable kept crashing under the -t 4 load. After that 0 passwords were found which was unexpected. Despite being a default credential on Metasploitable, msfadmin did not appear in the rockyou.txt wordlist.

Since the target credential was known from prior reconnaissance (manual FTP login confirmed msfadmin:msfadmin), I built a targeted custom wordlist containing the most likely candidates:

*echo -e "msfadmin\npassword\n123456\nroot\nadmin" > custom.txt*

*hydra -l msfadmin -P custom.txt ftp://192.168.56.105 -t 1 -V*

With that Hydra found the credentials immediately.

### **Findings:**

- ❖ Hydra 9.6 on modern Kali cannot brute force SSH on Metasploitable 2 due to legacy algorithm incompatibility - this is an environment limitation, not a tool failure.
- ❖ FTP is a viable alternative attack surface on Metasploitable - no encryption means no compatibility issues for Hydra.
- ❖ Standard wordlists like rockyou.txt are optimised for user-chosen passwords, not system default credentials. Service-specific defaults like 'msfadmin' may not appear.
- ❖ Prior reconnaissance dramatically improves brute force efficiency - knowing the likely credential and building a custom wordlist found the password instantly versus hours with rockyou.txt.

- ❖ Aggressive thread counts (-t 4+) can crash vulnerable target VMs. Responsible pentesting uses lower thread counts to avoid service disruption.
- ❖ Manual service verification (ftp, ssh commands) before running Hydra confirms the service is accessible and saves significant troubleshooting time.

### **Lessons Learned**

- ❖ Tools don't always work against every target out of the box - a penetration tester must be flexible enough to pivot to alternative attack surfaces when one approach fails.
- ❖ Live USB VirtualBox setups lose kernel module state and VM snapshots between sessions - always check vboxnet0 before starting a lab.
- ❖ A working manual login is the fastest way to confirm a service and its credentials before pointing an automated tool at it.
- ❖ Thread count is a responsibility setting, not just a speed setting, on fragile intentionally-vulnerable targets.

### **Note to Self:**

Confirm a service manually before pointing Hydra at it - it would have saved hours on the SSH dead end. Also: keep thread counts low against fragile intentionally-vulnerable VMs, and remember that default wordlists don't cover service-default credentials - build a custom list when the target is known.

### **What's Next?**

Lab 04 - Network Packet Capture & Traffic Analysis using tcpdump and Wireshark.